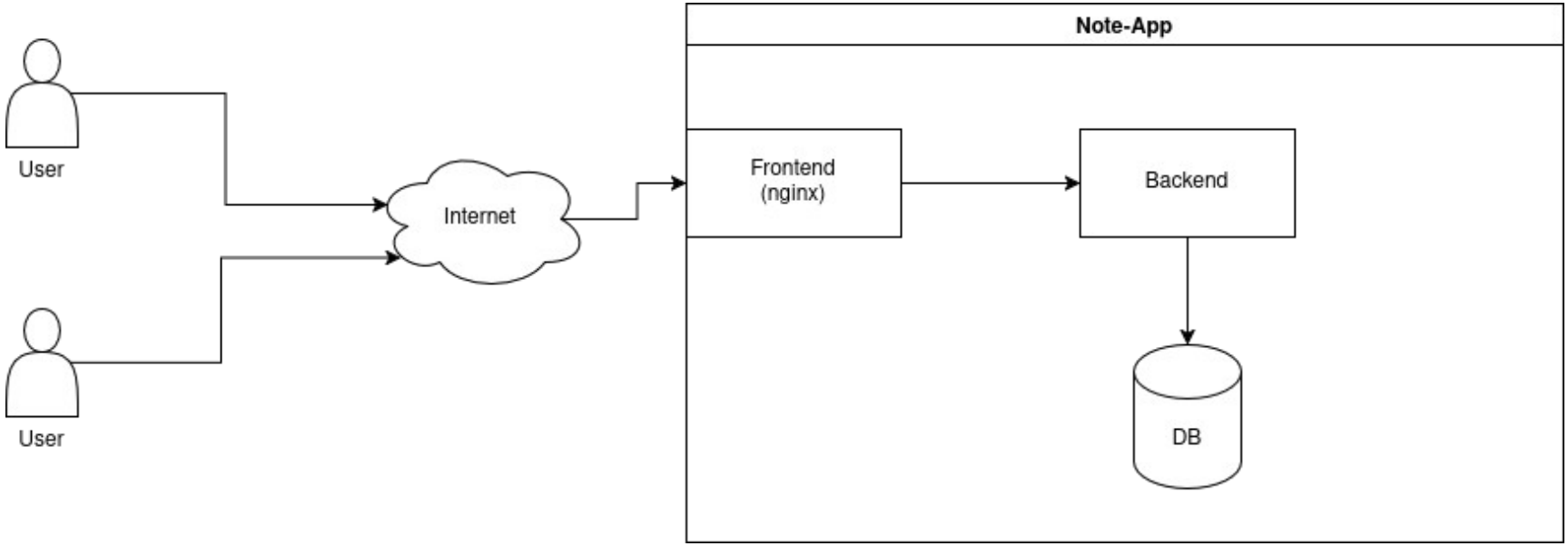
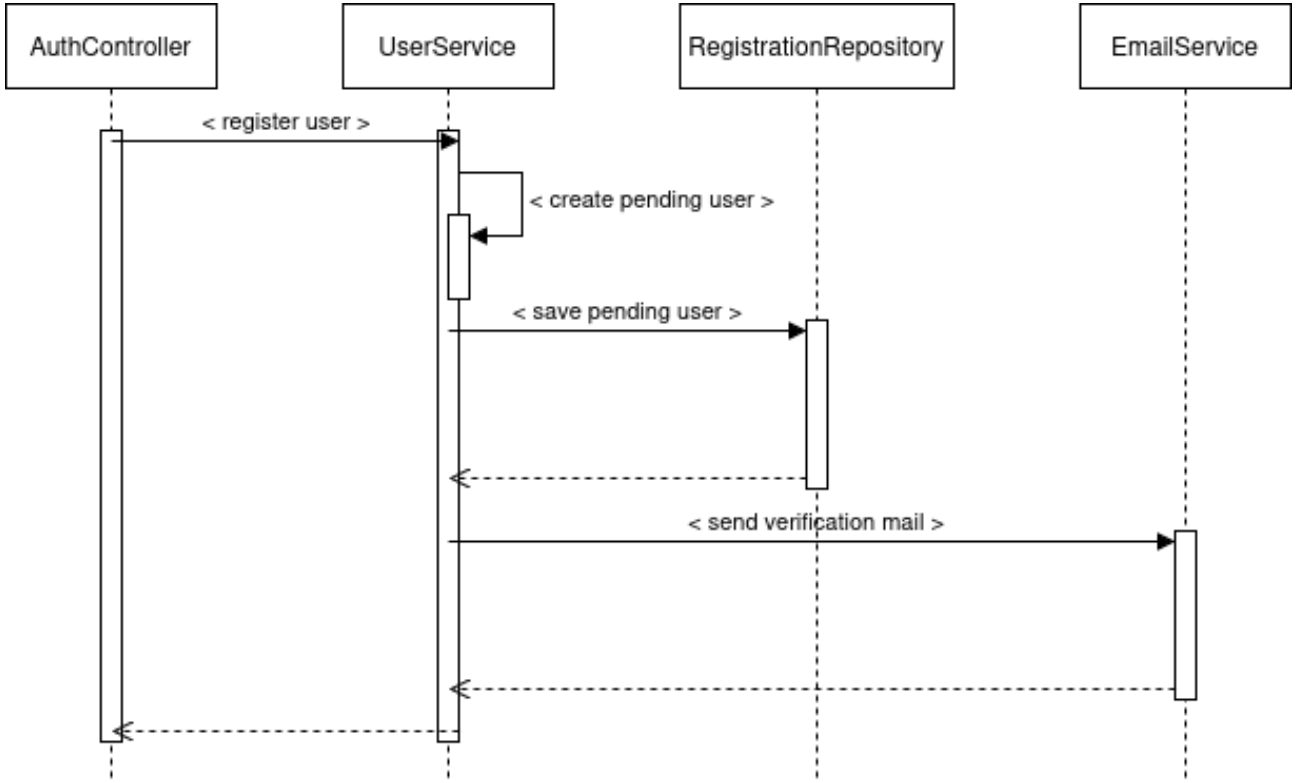
SSE - Projekt

Kaylin Althoff
Maxim Walter

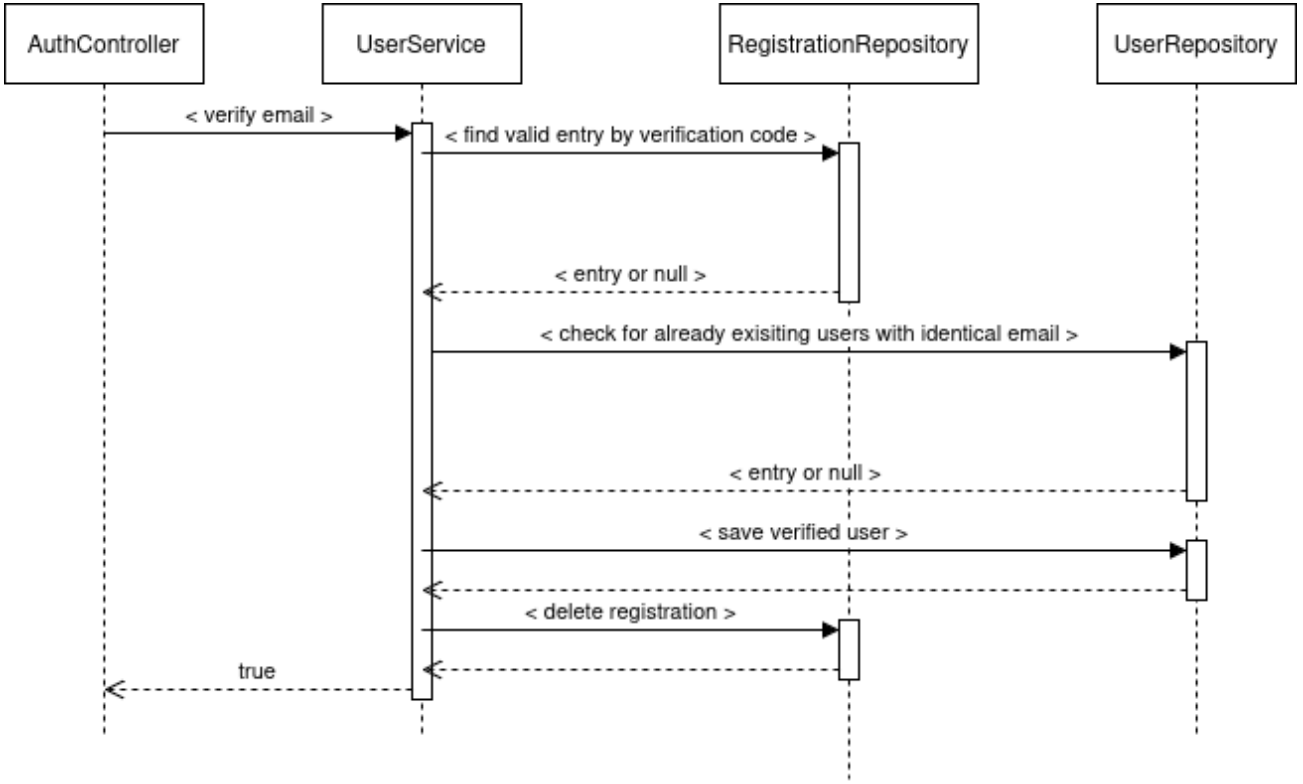
Aufbau der Anwendung



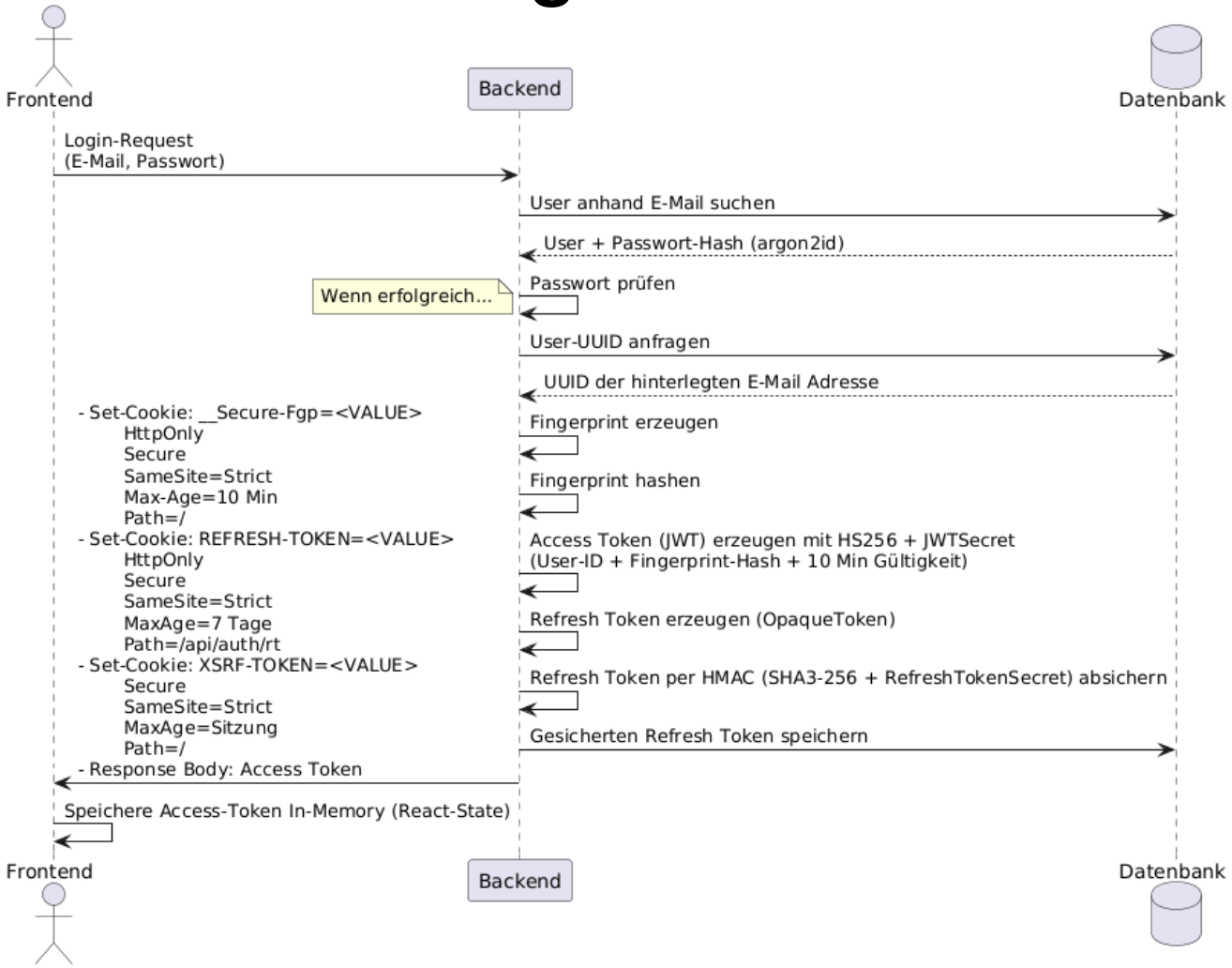
Registrierung

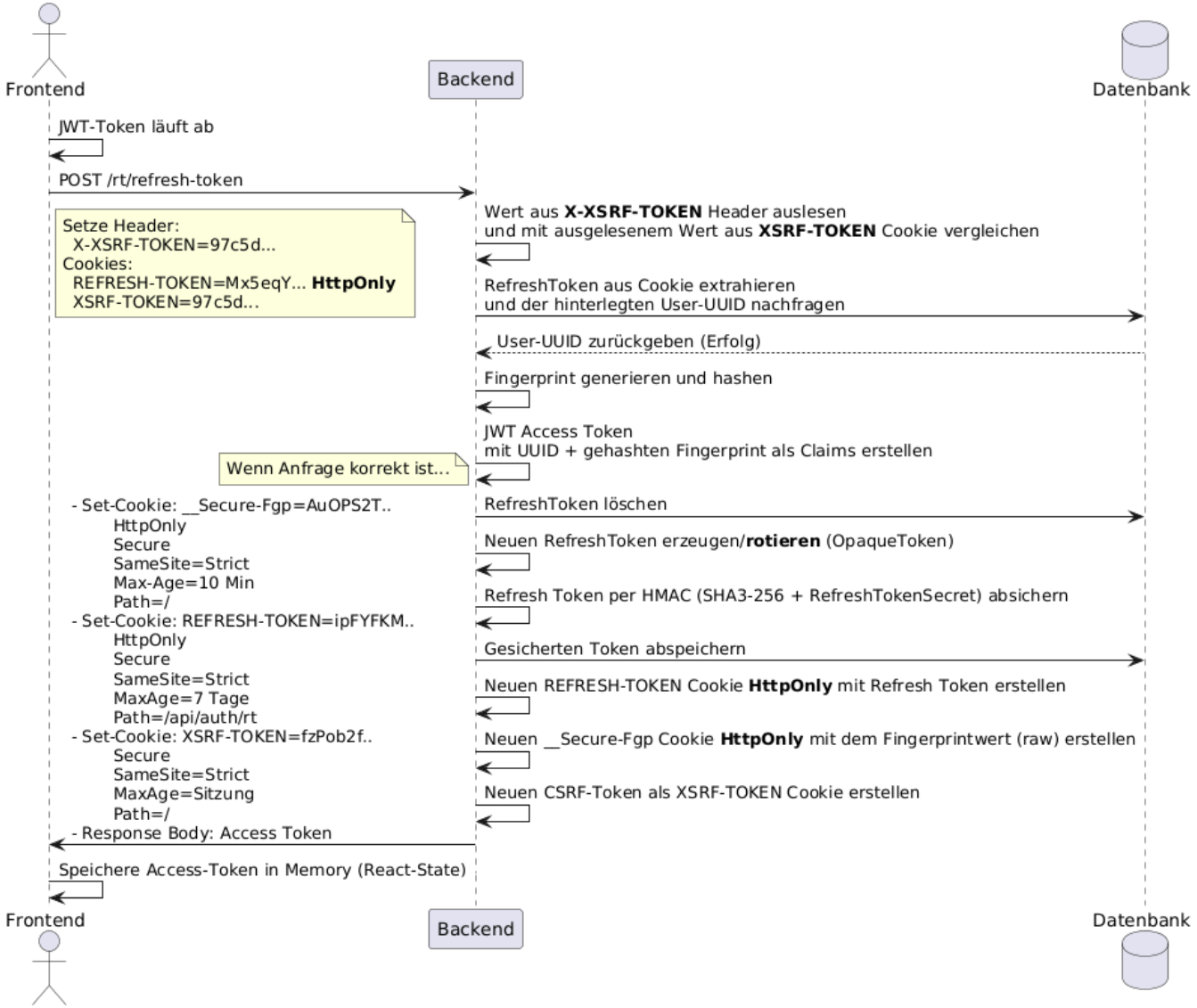


Registierung



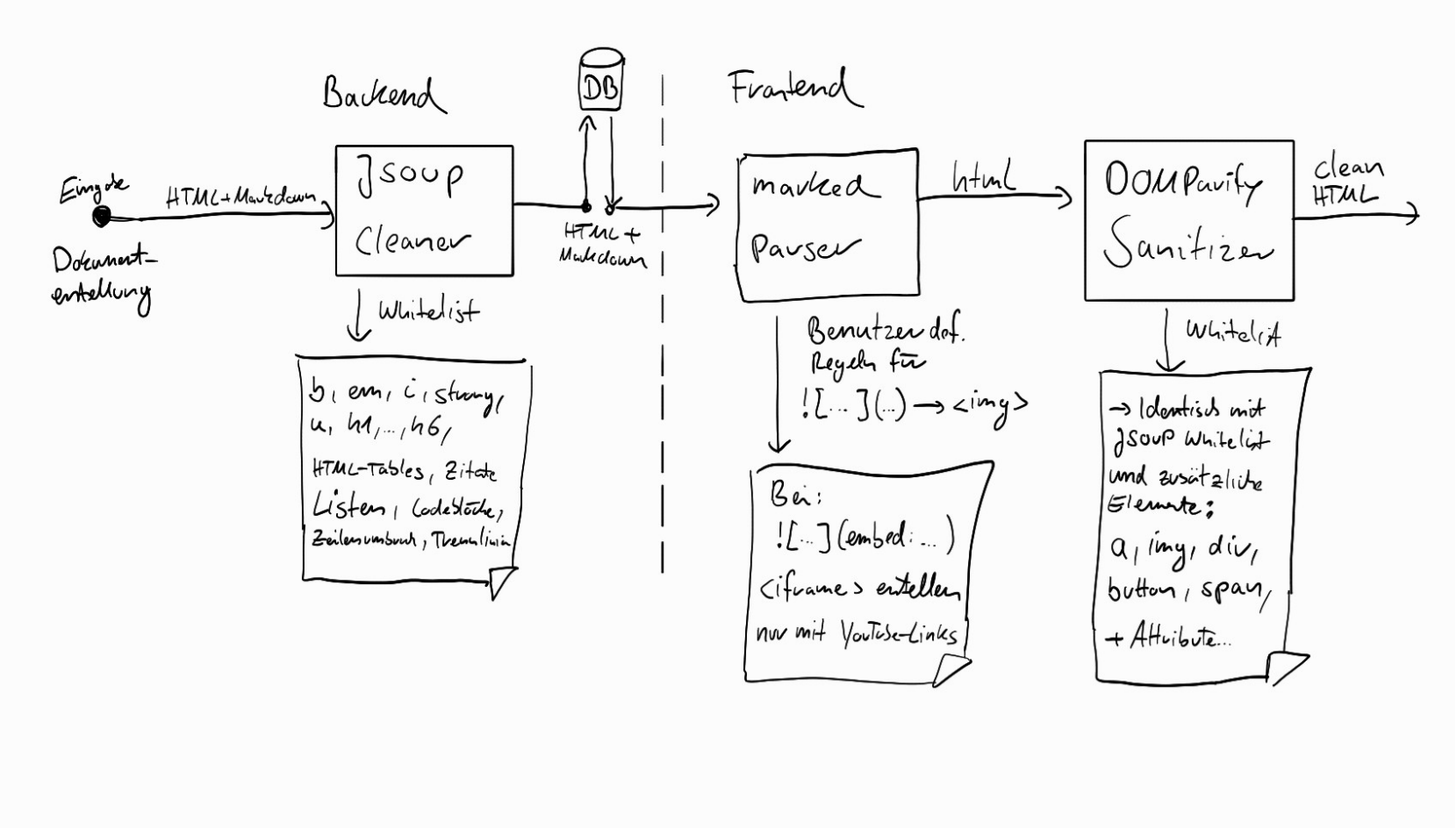
Login


Frontend
Backend
Datenbank
Login-Request
(E-Mail, Passwort)
User anhand E-Mail suchen
User + Passwort-Hash (argon2id)
Wenn erfolgreich...
Passwort prüfen
User-UUID anfragen
UUID der hinterlegten E-Mail Adresse
- Set-Cookie: __Secure-Fgp=<VALUE>
HttpOnly
Secure
SameSite=Strict
Max-Age=10 Min
Path=/
- Set-Cookie: REFRESH-TOKEN=<VALUE>
HttpOnly
Secure
SameSite=Strict
MaxAge=7 Tage
Path=/api/auth/rt
- Set-Cookie: XSRF-TOKEN=<VALUE>
Secure
SameSite=Strict
MaxAge=Sitzung
Path=/
- Response Body: Access Token
Fingerprint erzeugen
Fingerprint hashen
Access Token (JWT) erzeugen mit HS256 + JWTSecret
(User-ID + Fingerprint-Hash + 10 Min Gültigkeit)
Refresh Token erzeugen (OpaqueToken)
Refresh Token per HMAC (SHA3-256 + RefreshTokenSecret) absichern
Gesicherten Refresh Token speichern
Speichere Access-Token In-Memory (React-State)
Frontend
Backend
Datenbank


Frontend
Backend
Datenbank
JWT-Token läuft ab
POST /rt/refresh-token
Setze Header:
X-XSRF-TOKEN=97c5d...
Cookies:
REFRESH-TOKEN=Mx5eqY... HttpOnly
XSRF-TOKEN=97c5d...
Wert aus X-XSRF-TOKEN Header auslesen
und mit ausgelesenem Wert aus XSRF-TOKEN Cookie vergleichen
RefreshToken aus Cookie extrahieren
und der hinterlegten User-UUID nachfragen
User-UUID zurückgeben (Erfolg)
Fingerprint generieren und hashen
JWT Access Token
mit UUID + gehashten Fingerprint als Claims erstellen
Wenn Anfrage korrekt ist...
- Set-Cookie: __Secure-Fgp=AuOPS2T..
HttpOnly
Secure
SameSite=Strict
Max-Age=10 Min
Path=/
- Set-Cookie: REFRESH-TOKEN=ipFYFKM..
HttpOnly
Secure
SameSite=Strict
MaxAge=7 Tage
Path=/api/auth/rt
- Set-Cookie: XSRF-TOKEN=fzPob2f..
Secure
SameSite=Strict
MaxAge=Sitzung
Path=/
- Response Body: Access Token
RefreshToken löschen
Neuen RefreshToken erzeugen/rotieren (OpaqueToken)
Refresh Token per HMAC (SHA3-256 + RefreshTokenSecret) absichern
Gesicherten Token abspeichern
Neuen REFRESH-TOKEN Cookie HttpOnly mit Refresh Token erstellen
Neuen __Secure-Fgp Cookie HttpOnly mit dem Fingerprintwert (raw) erstellen
Neuen CSRF-Token als XSRF-TOKEN Cookie erstellen
Speichere Access-Token in Memory (React-State)
Frontend
Backend
Datenbank

Notiz abrufen

Notizerstellung und Anzeige



Proxy

- Nginx (backend proxy & hostet frontend)
- HTTPS
- Rate Limit
- Content Security Policy

Dependabot

- Inoffizielles Projekt dependabot-gitlab/dependabot
- Updates & vulnerability-alerts:
  - Docker
  - Docker-compose
  - maven
  - npm

CI Pipeline

- Docker-fähiger Runner
- Runner läuft selbst in docker
- Jobs:
  - Tests (Frontend & Backend)
  - Build & push

Livedemo